

TERMO DE ABERTURA DO PROJETO (TAP)

Atividade em grupo • Software web com utilidade social • Template para preenchimento

Disciplina	Segurança e Privacidade para ambiente WEB	Data	13/03/2026
Equipe (4 integrantes)	Gustavo Kawano, Marco Aurélio e Edson Renato	Versão	[v0.1.0]

1. Orientações da atividade

- Este projeto deve ser proposto e desenvolvido por grupos de exatamente 4 integrantes.
- O tema deve ter utilidade social. Caso o grupo tenha dificuldade para pensar em uma ideia, consultar Global Goals, Agenda 2030 e referências equivalentes.
- O sistema deve ser uma aplicação web em PHP com banco de dados relacional.
- O TAP deve ser preenchido de forma objetiva, coerente e verificável.
- Ao final, exportar o documento para PDF e entregar somente o PDF.

2. Requisitos mínimos obrigatórios do projeto

Item	Exigência mínima
Tipo de aplicação	Aplicação WEB.
Linguagem	PHP.
Banco de dados	SGBD relacional.
Perfis de usuário	Mais de um perfil de usuário.
Páginas funcionais	Ao menos 5 páginas funcionais com casos de uso bem definidos.
Tríade de autenticação	Página de cadastro/criar conta, página de login e página de mudança e/ou recuperação de senha.
Autenticação reforçada	Prever autenticação de duplo fator (2FA).
Modelo de negócio	Deve existir pelo menos um CRUD completo sobre o objeto principal do sistema.
Restrição importante	CRUD de usuário não conta para atender ao requisito principal.

Segurança	O projeto deve prever DFD, modelagem de ameaças e elicitação inicial de requisitos de segurança.
-----------	--

3. Identificação do projeto (Obrigatório 06/03)

Nome do projeto	SOS Golpes
Tema social escolhido	Segurança Digital e Proteção ao Cidadão
Patrocinador / cliente	Secretarias de Segurança Pública ou ONGs de Defesa do Consumidor
Resumo do projeto	O SOS Golpes é uma plataforma web em PHP voltada a capacitar o cidadão comum contra golpes de engenharia social. O sistema oferece ferramentas de análise em tempo real para links suspeitos (Deep Link), verificação de segurança em QR Codes e auditoria de vazamento de senhas, centralizando a defesa digital de forma acessível para reduzir prejuízos financeiros e exposição de dados de usuários leigos.

4. Justificativa e objetivos

4.1 Problema / oportunidade

O Brasil registra recordes de golpes via WhatsApp, SMS e QR Codes (Quishing). O público leigo, especialmente idosos e jovens em busca de emprego, é o mais afetado pela falta de ferramentas simples que validem a veracidade de URLs antes do clique. O projeto faz sentido agora devido ao aumento exponencial de estelionatos digitais e à carência de soluções gratuitas e educativas focadas no usuário final.

4.2 Público-alvo

Direto: Cidadãos comuns (usuários de internet), idosos e vítimas recorrentes de phishing.

Indireto: Instituições financeiras (redução de fraudes) e órgãos de segurança pública.

4.3 Objetivo geral

Desenvolver uma aplicação web funcional em PHP que permita a análise preventiva de ameaças digitais cotidianas para mitigar ataques de engenharia social contra o cidadão.

4.4 Objetivos específicos (3 a 6)

[OBJ-01] Implementar módulos de análise em tempo real para links suspeitos e QR Codes, permitindo que o usuário leigo verifique a reputação e a segurança de URLs antes do acesso.

[OBJ-02] Desenvolver a funcionalidade de auditoria de senhas (Password Health Checker), cruzando credenciais com bases de vazamentos (Dicionários/Leaks) para alertar os cidadãos sobre vulnerabilidades.

[OBJ-03] Criar um painel de monitoramento e gerenciamento para o perfil Administrador, possibilitando a visualização de tendências de novos golpes e o gerenciamento (CRUD) da base de vazamentos.

[OBJ-04] Aplicar princípios de segurança desde a concepção (Security by Design), garantindo a implementação da autenticação de duplo fator (2FA), controle de acesso por perfis (RBAC) e uso de hashes seguros (BCRYPT).

5. Modelagem funcional inicial do sistema

5.1 Perfis de usuário: Cidadão (Usuário Final) e Administrador (Gestor de Base de Ameaças).

5.2 Objeto principal do negócio: Análise de Ameaça (Entidade que registra o link/arquivo submetido e o resultado da verificação).

5.3 Regras gerais: O Cidadão pode criar análises e visualizar seu histórico; o Administrador pode atualizar dicionários de leaks e visualizar estatísticas globais.

5.4 Páginas funcionais obrigatórias

#	Página / tela	Perfil principal	Caso de uso / propósito fixo
1	Dashboard de Análise	Cidadão	Central de ferramentas para colar links e ler QR Codes.
2	Password Health Checker	Cidadão	Interface de verificação de senhas contra bases de vazamento.
3	Histórico de Consultas	Cidadão	Visualização de resultados anteriores e alertas de segurança.
4	Painel de Monitoramento	Admin	Visualizar quem acessou o sistema e quais análises foram feitas para identificar tentativas de abuso.
5	Gerenciamento de Base de Leaks	Admin	CRUD para importação de hashes de senhas vazadas (Dicionário)

6. Dados e arquitetura inicial

6.1 Banco de dados relacional

O modelo relacional é ideal para garantir a integridade dos perfis de usuários e o relacionamento entre as análises e as categorias de ameaças.

6.2 Principais entidades

Usuario, Perfil, Analise_Link, Registro_Leak, Log_Acesso.

6.3 Tecnologias principais

PHP, MySQL, HTML/CSS/JS, Apache (XAMPP/Laragon).

7. Segurança desde a concepção

7.1 DFD inicial

O fluxo inicia no usuário (Ator), passa pela validação de entrada (Processo), consulta bases externas de Whois/Reputação (Fluxo Externo) e armazena o log da consulta no Banco (Armazenamento)

7.2 Modelagem de ameaças

Spoofing: Alguém se passando por Admin para limpar logs de ameaças

Information Disclosure: Vazamento do histórico de consultas sensíveis do usuário.

7.3 Requisitos de segurança iniciais

Implementação de 2FA (obrigatório), controle de acesso por perfil (RBAC), hashes seguros para senhas (BCRYPT) e sanitização rigorosa de inputs.

8. Equipe e responsabilidades

Nome	Papel	Responsabilidades
Gustavo Kawano	Desenvolvedor	Desenvolvimento do core em PHP, implementação dos módulos de análise de links e QR Codes e configuração da Autenticação 2FA.
Marco Aurélio	Backend & Gerenciador de Base de Dados	Modelagem e administração do Banco de Dados Relacional, implementação do CRUD da base de vazamentos e lógica do Password Health Checker.

Edson Renato	Frontend & Analista de Segurança	Desenvolvimento das 5 páginas funcionais (UI/UX), elaboração do DFD e da Modelagem de Ameaças, e garantia da sanitização de inputs.
--------------	----------------------------------	---